INFORME DE AUDITORÍA ISO 27001

Sistema de Auditorías y Diagnóstico ISO 27001 — SADI

1. RESUMEN EJECUTIVO

Código de Auditoría:	AUD-5.1-8.34
Título:	[DEMO] Auditoría interna integral del SGSI - 93 controles del Anexo A
Auditor Responsable:	Julián Castaño
Fecha de Ejecución:	13/04/2026
Estado:	Finalizada

2. DETALLE DE CONTROLES Y RIESGOS

5.1 - Políticas para la seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Política de seguridad de la información aprobada por la dirección	3	3	ALTO (9)	*"La política existe como borrador desde noviembre de 2025 y no ha sido aprobada. No tiene número de versión, fecha de vigencia ni responsable de revisión."* **Adjunto:** Ver Evidencia
Comunicación y reconocimiento de la política por el personal	3	3	ALTO (9)	*"El borrador no se ha publicado. En la muestra de 8 empleados entrevistados, ninguno pudo indicar dónde consultarla."* Sin adjuntos

5.2 - Roles y responsabilidades de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Definición y asignación formal de roles de seguridad de la información	3	3	ALTO (9)	*"Los roles están enunciados en el manual de funciones pero no se asignaron nominalmente. No hay un responsable designado para la gestión de incidentes."* Sin adjuntos
Comunicación de las responsabilidades al personal involucrado	3	3	ALTO (9)	*"No hay evidencia de comunicación ni de aceptación de responsabilidades. El coordinador de TI desconocía que le corresponde reportar el desempeño del SGSI a la gerencia."* Sin adjuntos

5.10 - Uso aceptable de la información y otros activos asociados

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Reglas de uso aceptable de la información y de los activos	1	2	BAJO (2)	*"El reglamento interno de trabajo incorpora las reglas de uso aceptable y se firma en la inducción. Se verificaron 10 expedientes, todos con la constancia firmada."* Sin adjuntos

5.32 - Derechos de propiedad intelectual

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Procedimientos para proteger los derechos de propiedad intelectual	2	3	MODERADO (6)	*"No hay inventario de licencias. Se identificaron 6 equipos con software de diseño sin licencia vigente y una hoja de cálculo de gestión desarrollada por un exempleado sin acuerdo de cesión de derechos."* Sin adjuntos

5.3 - Segregación de funciones

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Segregación de funciones en conflicto	2	4	MODERADO (8)	*"La auxiliar contable registra las facturas, aprueba los pagos y concilia el extracto bancario. No hay control compensatorio documentado."* Sin adjuntos

5.4 - Responsabilidades de la dirección

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
La dirección exige la aplicación de la seguridad de la información	1	2	BAJO (2)	*"La gerencia trata la seguridad de la información como punto fijo del comité mensual. Se revisaron las actas de los últimos seis meses, todas con seguimiento a compromisos."* Sin adjuntos

5.14 - Transferencia de información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Reglas y acuerdos para la transferencia de información con terceros	3	4	ALTO (12)	*"No existen reglas de transferencia. Los archivos de cartera se envían a la empresa de cobranza por correo personal de Gmail y por WhatsApp, sin cifrado ni acuerdo de confidencialidad específico."* Sin adjuntos
Protección de la información durante la transferencia	3	3	ALTO (9)	*"Los respaldos que se llevan a la sede alterna viajan en un disco externo sin cifrar, en transporte público y sin registro de custodia."* Sin adjuntos

5.6 - Contacto con grupos de interés especiales

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Contacto con grupos de interés especiales y foros de seguridad	2	3	MODERADO (6)	*"La organización no participa en ningún foro sectorial ni recibe boletines de seguridad. La información sobre amenazas llega de forma incidental por redes sociales."* Sin adjuntos

5.7 - Inteligencia de amenazas

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Recopilación y análisis de inteligencia de amenazas	2	3	MODERADO (6)	*"No se recopila información de amenazas. No hay suscripción a avisos del proveedor del ERP ni a alertas de vulnerabilidades de los productos en uso."* Sin adjuntos

5.8 - Seguridad de la información en la gestión de proyectos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Integración de la seguridad de la información en la gestión de proyectos	1	2	BAJO (2)	*"La plantilla de acta de inicio de proyecto incluye el apartado de requisitos de seguridad. Se verifico su diligenciamiento en los tres proyectos de 2026."* Sin adjuntos

5.9 - Inventario de información y otros activos asociados

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Inventario de información y otros activos asociados, con propietarios asignados	1	2	BAJO (2)	*"Inventario INV-ACT-2026 actualizado en febrero, con 132 activos y propietario asignado. Se verifico por muestreo de 12 activos, todos localizados."* Sin adjuntos

5.11 - Devolución de activos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Devolución de activos al terminar el empleo o el contrato	1	2	BAJO (2)	*"El formato de paz y salvo incluye la devolución de equipos, carnet y llaves. Se revisaron las 4 desvinculaciones de 2026, todas con formato completo."* Sin adjuntos

5.12 - Clasificación de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Esquema de clasificación de la información definido y aplicado	2	4	MODERADO (8)	*"No hay esquema de clasificación. La información comercial, la de nómina y la pública se guardan en la misma carpeta compartida con permisos de lectura para todo el dominio."* Sin adjuntos

5.13 - Etiquetado de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Procedimientos de etiquetado acordes al esquema de clasificación	2	3	MODERADO (6)	*"Al no existir clasificación, tampoco hay etiquetado. Los documentos impresos con datos de clientes no llevan marca de confidencialidad."* Sin adjuntos

5.15 - Control de acceso

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Existencia de una política de control de acceso aprobada y revisada	5	5	EXTREMO (25)	*"No existe política de control de acceso documentada ni aprobada. Las reglas de acceso se definen caso por caso por el contratista de TI, sin criterio escrito y sin aprobación de los dueños de la información."* Sin adjuntos
Revisión periódica de los accesos concedidos	5	4	EXTREMO (20)	*"No se ha ejecutado ninguna revisión de accesos desde el inicio de operaciones del ERP en 2023. Se identificaron 7 cuentas activas de personal retirado, dos de ellas con perfil de aprobación de órdenes de compra."* **Adjunto:** Ver Evidencia
Segregación entre el acceso lógico y el acceso físico a la información	4	4	EXTREMO (16)	*"El archivo físico de contratos de la bodega usa la misma llave maestra que la oficina de tesorería; la relación de tenedores de llave no está actualizada."* Sin adjuntos

5.19 - Seguridad de la información en las relaciones con los proveedores

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Proceso documentado para gestionar los riesgos de seguridad con proveedores	4	5	EXTREMO (20)	*"No hay proceso de gestión de riesgos de proveedores. El proveedor del ERP tiene acceso remoto permanente con credenciales de administrador compartidas entre tres técnicos, sin registro de sesiones ni ventana de mantenimiento acordada."* Sin adjuntos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Identificación de los activos de información accesibles a terceros	4	4	EXTREMO (16)	*"No existe inventario de qué información puede ver cada proveedor. El proveedor de nómina recibe el archivo completo de empleados, incluidos datos de salud, cuando solo requiere los campos de liquidación."* Sin adjuntos

5.16 - Gestión de identidades

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión del ciclo de vida completo de las identidades	1	2	BAJO (2)	*"Existe procedimiento formal de alta y baja de usuarios con solicitud del jefe inmediato. Se verificaron las 11 altas de 2026."* Sin adjuntos

5.17 - Información de autenticación

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión controlada de la información de autenticación	1	2	BAJO (2)	*"Las credenciales iniciales se entregan en sobre cerrado con cambio obligatorio en el primer ingreso. Política de complejidad activa en el directorio."* Sin adjuntos

5.18 - Derechos de acceso

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Aprovisionamiento, revisión y retiro de derechos de acceso	1	2	BAJO (2)	*"El aprovisionamiento sigue la matriz de perfiles por cargo. El retiro esta cubierto por el procedimiento de desvinculación, con constancia en los 4 casos de 2026."* Sin adjuntos

5.28 - Recopilación de evidencias

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Procedimientos para identificar, recopilar y preservar evidencias	3	3	ALTO (9)	*"No hay procedimiento de recopilación de evidencias. Tras el intento de fraude por correo de enero de 2026 se reinició el equipo afectado antes de preservar los registros, lo que impidió cualquier análisis posterior."* Sin adjuntos

5.20 - Abordar la seguridad de la información en los acuerdos con proveedores

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Requisitos de seguridad acordados en los contratos con proveedores	1	2	BAJO (2)	*"Los contratos de los cinco proveedores críticos incluyen cláusula de confidencialidad y de tratamiento de datos personales, revisada por el área jurídica."* Sin adjuntos

5.21 - Gestión de la seguridad de la información en la cadena de suministro de TIC

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión de riesgos en la cadena de suministro de productos y servicios TIC	2	4	MODERADO (8)	*"No se evalúa la seguridad de los proveedores antes de contratarlos. El hosting del sitio web se contrató por precio, sin revisar certificaciones ni ubicación de los datos."* Sin adjuntos

5.22 - Seguimiento, revisión y gestión de cambios de los servicios de los proveedores

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Seguimiento y revisión de los servicios prestados por los proveedores	1	2	BAJO (2)	*"Se realizan comités trimestrales de servicio con el proveedor del ERP y del hosting, con acta y acuerdos de nivel de servicio revisados."* Sin adjuntos

5.23 - Seguridad de la información para el uso de servicios en la nube

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Requisitos de seguridad para la adquisición y uso de servicios en la nube	2	4	MODERADO (8)	*"Se usan Google Drive y Dropbox personales para documentos de trabajo, sin contrato empresarial, sin control de la organización sobre las cuentas y sin proceso de salida."* Sin adjuntos

5.24 - Planificación y preparación de la gestión de incidentes de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Planificación y preparación de la gestión de incidentes	1	2	BAJO (2)	*"Existe procedimiento de gestión de incidentes PR-TI-004 con roles, canal de reporte y escalamiento definidos."* Sin adjuntos

5.25 - Evaluación y decisión sobre eventos de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Evaluación de eventos y decisión sobre su clasificación como incidentes	2	3	MODERADO (6)	*"Los eventos se atienden por teléfono con el contratista de TI. No hay criterio para decidir cuándo un evento es un incidente ni quién lo declara."* Sin adjuntos

5.26 - Respuesta a incidentes de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Respuesta a incidentes conforme a los procedimientos documentados	1	2	BAJO (2)	*"Los dos incidentes registrados en 2026 se atendieron según el procedimiento, con registro de tiempos de detección y de cierre."* Sin adjuntos

5.27 - Aprender de los incidentes de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Uso del conocimiento de los incidentes para fortalecer los controles	2	3	MODERADO (6)	*"Los dos incidentes de 2025 no generaron lección aprendida ni cambio en los controles. El mismo vector de correo fraudulento se repitió en enero de 2026."* Sin adjuntos

6.1 - Investigación de antecedentes

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Verificación de antecedentes antes de la contratación	3	3	ALTO (9)	*"No se realiza verificación de antecedentes. En la muestra de 10 expedientes, ninguno incluye consulta de antecedentes judiciales ni verificación de referencias laborales, incluidos los dos cargos con acceso a tesorería."* Sin adjuntos
Proporcionalidad de la verificación según la criticidad del cargo	3	3	ALTO (9)	*"No hay criterio que diferencie los cargos con acceso a información sensible del resto. El auxiliar de bodega y el coordinador de TI siguen el mismo proceso de ingreso."* Sin adjuntos

5.29 - Seguridad de la información durante la interrupción

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Mantenimiento de la seguridad de la información durante la interrupción	2	4	MODERADO (8)	*"El plan de continuidad cubre la operación comercial pero no define como se preserva la confidencialidad de la información cuando se opera desde la sede alterna."* Sin adjuntos

5.30 - Preparación de TIC para la continuidad del negocio

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Preparación de TIC para la continuidad del negocio, probada periódicamente	2	4	MODERADO (8)	*"Existen objetivos de recuperación verbales (RTO de 4 horas) pero nunca se han probado. La última prueba de restauración documentada es de 2024."* Sin adjuntos

5.31 - Requisitos legales, estatutarios, reglamentarios y contractuales

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Identificación y actualización de los requisitos legales y contractuales	1	2	BAJO (2)	*"Matriz legal MAT-LEG-2026 actualizada, con Ley 1273, Ley 1581, Decreto 1377 y las obligaciones contractuales de los cinco clientes principales."* Sin adjuntos

5.33 - Protección de registros

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección de los registros contra pérdida y acceso no autorizado	1	2	BAJO (2)	*"Los registros contables y laborales se conservan con respaldo diario y acceso restringido al área correspondiente. Tabla de retención documental vigente."* Sin adjuntos

5.34 - Privacidad y protección de la información personal

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Cumplimiento de los requisitos de privacidad y protección de datos personales	2	4	MODERADO (8)	*"No se ha registrado la base de datos de clientes ante el RNBD de la SIC. El aviso de privacidad del sitio web no describe las finalidades del tratamiento ni el procedimiento para ejercer los derechos del titular (Ley 1581 y Decreto 1377)."* Sin adjuntos

5.35 - Revisión independiente de la seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Revisión independiente de la seguridad de la información	1	2	BAJO (2)	*"La revisión independiente la realiza la auditoría interna con el programa aprobado por la gerencia. Esta auditoría es parte de esa evidencia."* Sin adjuntos

5.36 - Cumplimiento de las políticas, reglas y estándares de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Cumplimiento de políticas, reglas y estándares de seguridad	1	2	BAJO (2)	*"El comité de seguridad revisa el cumplimiento a intervalos programados y deja constancia en acta. Se revisaron las actas de los últimos seis meses."* Sin adjuntos

5.37 - Procedimientos de operación documentados

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Procedimientos de operación documentados y disponibles	1	2	BAJO (2)	*"Los procedimientos de operación de TI están documentados y disponibles en la carpeta de calidad. Se verifico la vigencia de los seis procedimientos del proceso."* Sin adjuntos

6.4 - Proceso disciplinario

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Proceso disciplinario formal ante incumplimientos de seguridad	3	4	ALTO (12)	*"No existe proceso disciplinario asociado a la seguridad de la información. El reglamento interno no tipifica el incumplimiento de la política como falta, por lo que la organización no podría sancionar una fuga deliberada de información."* **Adjunto:** Ver Evidencia
Comunicación previa del proceso disciplinario al personal	3	3	ALTO (9)	*"Al no existir el proceso, no hay comunicación. Los empleados entrevistados no conocen consecuencia alguna por incumplir la política de seguridad."* Sin adjuntos

6.2 - Términos y condiciones de empleo

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Términos y condiciones de empleo que recogen las responsabilidades de seguridad	2	3	MODERADO (6)	*"Los contratos incluyen cláusula de confidencialidad genérica, pero no detallan las responsabilidades de seguridad de la información ni su vigencia tras la terminación."* Sin adjuntos

6.3 - Concienciación, educación y formación en seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Concienciación, educación y formación en seguridad de la información	1	2	BAJO (2)	*"La inducción incluye un módulo de seguridad de la información de dos horas con evaluación. Se verificaron las 11 inducciones de 2026, todas con constancia y nota."* Sin adjuntos

7.10 - Medios de almacenamiento

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión de los medios de almacenamiento durante su ciclo de vida	3	3	ALTO (9)	*"No hay control de medios extraibles. Se encontraron 14 memorias USB sin inventariar en los puestos de trabajo, dos de ellas con copias de la base de clientes sin cifrar."* Sin adjuntos
Protección de los medios durante el transporte	3	3	ALTO (9)	*"El disco de respaldo semanal viaja a la sede alterna en el vehículo particular de un empleado, sin cifrado, sin estuche seguro y sin acta de entrega."* Sin adjuntos

6.5 - Responsabilidades tras el cese o cambio de empleo

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Responsabilidades que continuan tras el cese o el cambio de empleo	2	3	MODERADO (6)	*"El paz y salvo cubre la devolución de activos pero no recuerda por escrito las obligaciones de confidencialidad posteriores al retiro. En los cambios internos de cargo no se revisan los accesos heredados."* Sin adjuntos

6.6 - Acuerdos de confidencialidad o no divulgación

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Acuerdos de confidencialidad vigentes y revisados	1	2	BAJO (2)	*"Los acuerdos de confidencialidad del personal de planta están firmados, pero los 6 contratistas y practicantes activos no tienen acuerdo suscrito."* Sin adjuntos

6.7 - Trabajo remoto

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Medidas de seguridad para el trabajo remoto	1	2	BAJO (2)	*"La política de teletrabajo exige VPN, equipo corporativo y prohibición de redes públicas sin túnel. Se verifico la configuración en los 5 equipos asignados a teletrabajo."* Sin adjuntos

6.8 - Notificación de eventos de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Canal definido para que el personal notifique eventos de seguridad	2	3	MODERADO (6)	*"El canal de reporte es el teléfono personal del coordinador de TI. No hay buzón ni registro de los eventos reportados, y fuera del horario laboral no hay cobertura."* Sin adjuntos

7.1 - Perímetros de seguridad física

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Perímetros de seguridad física definidos	1	2	BAJO (2)	*"El perímetro esta definido y documentado en el plano PL-SEG-01, con tres zonas: pública, administrativa y restringida. Se verifico en recorrido."* Sin adjuntos

7.2 - Entrada física

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Controles de entrada física a las áreas seguras	1	2	BAJO (2)	*"El ingreso a la zona administrativa se controla con carnet de proximidad y registro de visitantes con documento. Se reviso el libro de visitantes del último trimestre."* Sin adjuntos

7.3 - Seguridad de oficinas, salas e instalaciones

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Seguridad de oficinas, salas e instalaciones	1	2	BAJO (2)	*"Las áreas de tesorería y archivo tienen acceso restringido con llave controlada y relación de tenedores actualizada."* Sin adjuntos

7.4 - Monitoreo de la seguridad física

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Monitoreo de la seguridad física de las instalaciones	2	3	MODERADO (6)	*"El CCTV cubre el acceso principal y la bodega, pero no el cuarto de comunicaciones. La grabación se conserva 7 días, por debajo de los 30 que exige el contrato con el cliente principal."* Sin adjuntos

7.5 - Protección contra amenazas físicas y ambientales

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección contra amenazas físicas y ambientales	2	4	MODERADO (8)	*"El cuarto de comunicaciones no tiene detección de incendio ni extintor de agente limpio. Está bajo una tubería de agua del piso superior, sin bandeja de contención."* Sin adjuntos

7.6 - Trabajo en áreas seguras

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Reglas para el trabajo en áreas seguras	2	3	MODERADO (6)	*"No hay reglas escritas para el cuarto de comunicaciones. Se observó personal de aseo trabajando allí sin acompañamiento y con la puerta abierta."* Sin adjuntos

7.7 - Escritorio limpio y pantalla limpia

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Política de escritorio limpio y pantalla limpia	2	3	MODERADO (6)	*"En el recorrido del 13/04/2026 se encontraron 9 de 22 puestos con documentos de clientes a la vista y 4 sesiones desbloqueadas sin usuario presente. No hay bloqueo automático configurado por directiva."* **Adjunto:** Ver Evidencia

7.8 - Ubicación y protección del equipo

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Ubicación y protección del equipo frente a riesgos del entorno	2	4	MODERADO (8)	*"El servidor principal está en un rack abierto dentro del área de contabilidad, expuesto a polvo, a manipulación accidental y a la circulación de personal no autorizado."* Sin adjuntos

7.9 - Seguridad de los activos fuera de las instalaciones

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Seguridad de los activos fuera de las instalaciones	2	4	MODERADO (8)	*"Los 7 portátiles asignados a la fuerza comercial no tienen cifrado de disco ni control de borrado remoto. En 2025 se perdió uno con la cartera de clientes de la zona norte y no se pudo verificar el alcance de la exposición."* Sin adjuntos

7.14 - Eliminación o reutilización segura del equipo

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Procedimiento de eliminación o reutilización segura de equipos	3	4	ALTO (12)	*"No existe procedimiento de borrado seguro. Los 5 equipos dados de baja en 2025 se donaron con los discos intactos; uno contenía la carpeta de nómina de tres vigencias."* Sin adjuntos

7.12 - Seguridad del cableado

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección del cableado de energía y de telecomunicaciones	1	2	BAJO (2)	*"El cableado de red del área comercial corre por el piso sin canaleta en dos tramos y el patch panel no está rotulado, lo que dificulta la trazabilidad de los puntos."* Sin adjuntos

7.13 - Mantenimiento de equipos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Mantenimiento de equipos conforme a las recomendaciones del fabricante	2	2	MODERADO (4)	*"Existe cronograma de mantenimiento preventivo, pero solo se ejecutó el 60 % de las actividades programadas en 2025 y no hay registro de las dos últimas intervenciones al servidor."* Sin adjuntos

8.8 - Gestión de vulnerabilidades técnicas

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Ejecución periódica de pruebas de vulnerabilidad sobre sistemas y aplicaciones	5	5	EXTREMO (25)	*"No se han ejecutado pruebas de vulnerabilidad desde la puesta en producción del ERP en 2023. El escaneo puntual realizado durante esta auditoría sobre el segmento de servidores reportó 3 vulnerabilidades críticas y 11 altas, entre ellas SMBv1 habilitado y un servicio de escritorio remoto expuesto sin segundo factor."* **Adjunto:** Ver Evidencia
Proceso de gestión y remediación de las vulnerabilidades identificadas	5	4	EXTREMO (20)	*"No hay proceso de remediación ni responsable asignado. Las actualizaciones de seguridad del sistema operativo están en modo manual y el último parche aplicado al servidor es de septiembre de 2025."* Sin adjuntos
Definición de plazos de remediación según la criticidad	4	4	EXTREMO (16)	*"No existen acuerdos de plazo para remediar. Las vulnerabilidades reportadas por el proveedor del ERP en 2025 siguen abiertas sin fecha compromiso."* Sin adjuntos

8.1 - Dispositivos de punto final del usuario

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección de los dispositivos de punto final del usuario	1	2	BAJO (2)	*"Política de dispositivos vigente, con antimalware gestionado y bloqueo de pantalla en los 22 equipos corporativos verificados."* Sin adjuntos

8.2 - Derechos de acceso privilegiado

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Restricción y control de los derechos de acceso privilegiado	2	4	MODERADO (8)	*"Existen 6 cuentas con privilegios de administrador de dominio para un equipo de TI de 2 personas. Dos pertenecen al proveedor y una no tiene responsable identificado."* Sin adjuntos

8.3 - Restricción de acceso a la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Restricción del acceso a la información según la política de control de acceso	2	4	MODERADO (8)	*"Los perfiles del ERP no siguen el principio de mínimo privilegio: el perfil comercial permite consultar la nómina y los costos de compra."* Sin adjuntos

8.4 - Acceso al código fuente

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Custodia y restricción del acceso al código fuente	1	1	BAJO (1)	*"La organización no custodia código fuente. El de los desarrollos a la medida reside en un repositorio privado del proveedor, con acceso nominal y registro de cambios; se verifico la lista de usuarios autorizados. Se deja constancia para la decisión de aplicabilidad."* Sin adjuntos

8.5 - Autenticación segura

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Uso de técnicas de autenticación segura	2	4	MODERADO (8)	*"El acceso al ERP y al correo usa solo usuario y contraseña. No hay segundo factor ni siquiera para las cuentas administrativas ni para el acceso remoto."* Sin adjuntos

8.6 - Gestión de la capacidad

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Seguimiento y proyección de la capacidad de los recursos	1	2	BAJO (2)	*"Se monitorean el almacenamiento y la memoria del servidor con alertas al 80 %. La proyección de capacidad se revisa en el comité trimestral de TI."* Sin adjuntos

8.7 - Protección contra malware

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección contra el software malicioso	1	2	BAJO (2)	*"Antimalware corporativo con consola centralizada, firmas actualizadas y análisis programado semanal. Se verifico el estado de los 22 equipos, todos al día."* Sin adjuntos

8.10 - Eliminación de información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Eliminación de la información cuando deja de ser necesaria	3	3	ALTO (9)	*"No hay criterio ni procedimiento de eliminación de información. La carpeta compartida conserva bases de datos de clientes exportadas desde 2019, con datos personales cuya finalidad de tratamiento ya caduco."* Sin adjuntos

8.9 - Gestión de la configuración

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión de la configuración de los sistemas	1	2	BAJO (2)	*"Existen lineas base de configuración para estaciones y servidor, documentadas y aplicadas mediante plantilla de instalación."* Sin adjuntos

8.19 - Instalación de software en sistemas operativos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Reglas que regulen la instalación de software en los sistemas operativos	4	3	ALTO (12)	*"No hay restricción de instalación: los 22 usuarios tienen privilegios de administrador local. Se identificaron 9 equipos con software descargado de internet, incluido un gestor de descargas con adware reportado."* Sin adjuntos
Control sobre el software autorizado en la organización	3	3	ALTO (9)	*"No existe lista de software autorizado ni inventario de lo instalado. El área de TI no sabe que aplicaciones corren en los equipos de la fuerza comercial."* Sin adjuntos

8.11 - Enmascaramiento de datos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Enmascaramiento de datos en entornos distintos de producción	2	3	MODERADO (6)	*"El entorno de pruebas del ERP usa una copia integra de la base de producción con datos reales de clientes, accesible a los técnicos del proveedor."* Sin adjuntos

8.12 - Prevención de fuga de datos

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Medidas de prevención de fuga de datos	2	3	MODERADO (6)	*"No hay control sobre la salida de información: los puertos USB están habilitados sin restricción y el correo corporativo permite adjuntar archivos de cualquier tamaño a destinatarios externos sin alerta."* Sin adjuntos

8.14 - Redundancia de las instalaciones de procesamiento de información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Redundancia de las instalaciones de procesamiento	1	2	BAJO (2)	*"El servidor tiene arreglo RAID 1 y fuente redundante. El enlace de internet cuenta con canal de contingencia de otro proveedor, probado en marzo de 2026."* Sin adjuntos

8.15 - Registro de actividad (logging)

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Registro de eventos y actividades de los sistemas	1	2	BAJO (2)	*"El ERP y el directorio registran eventos de autenticación y cambios, con retención de 90 días. Se verifico la disponibilidad de los registros del último trimestre."* Sin adjuntos

8.16 - Actividades de monitoreo

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Actividades de monitoreo de la red y de los sistemas	2	4	MODERADO (8)	*"No hay monitoreo de seguridad. Nadie revisa los registros y no existen alertas configuradas; los dos incidentes de 2025 los detectó un usuario, no un control."* Sin adjuntos

8.17 - Sincronización del reloj

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Sincronización de relojes con una fuente de tiempo confiable	1	2	BAJO (2)	*"Servidor y estaciones sincronizan con el servicio NTP del proveedor de dominio. Se verifico la desviación en 5 equipos, inferior a un segundo."* Sin adjuntos

8.18 - Uso de programas de utilidades privilegiados

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Restricción del uso de programas de utilidad privilegiados	1	2	BAJO (2)	*"Las herramientas de administración están instaladas únicamente en el equipo del coordinador de TI, con inventario y justificación registrados."* Sin adjuntos

8.20 - Seguridad de redes

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Documentación, gestión y control de la infraestructura de red	3	4	ALTO (12)	*"No existe diagrama de red actualizado ni inventario de equipos activos. El último diagrama es de 2022 y no refleja los dos switches ni el enlace de contingencia incorporados desde entonces."* Sin adjuntos
Protección de la información en tránsito por la red	3	3	ALTO (9)	*"La red inalámbrica corporativa y la de invitados comparten el mismo SSID y la misma clave, que no se cambia desde 2023 y esta escrita en la recepción."* **Adjunto:** Ver Evidencia

8.32 - Gestión de cambios

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Gestión documentada de los cambios en los sistemas de información	3	3	ALTO (9)	*"No hay procedimiento de gestión de cambios. Las modificaciones al ERP las aplica el proveedor directamente en producción, sin solicitud formal, sin aprobación y sin plan de reversión. Un cambio de marzo de 2026 dejo sin facturar dos días."* Sin adjuntos

8.21 - Seguridad de los servicios de red

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Seguridad de los servicios de red contratados	1	2	BAJO (2)	*"Los servicios de red están soportados en contrato con acuerdos de nivel de servicio y cláusula de seguridad, revisados en el comité trimestral."* Sin adjuntos

8.22 - Segregación de redes

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Segregación de redes según criticidad y tipo de servicio	2	4	MODERADO (8)	*"La red es plana: servidores, estaciones de trabajo, cámaras de CCTV y red de invitados comparten el mismo segmento y direccionamiento."* Sin adjuntos

8.23 - Filtrado web

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Filtrado del acceso a sitios web externos	2	3	MODERADO (6)	*"No hay filtrado web. La navegación es libre desde todos los equipos, incluido el servidor, lo que amplia la superficie de exposición a descargas maliciosas."* Sin adjuntos

8.24 - Uso de criptografía

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Política de uso de criptografía y gestión de claves	1	2	BAJO (2)	*"Política de criptografía vigente: TLS 1.2 o superior en los servicios publicados y cifrado del respaldo en la nube. Custodia de claves documentada."* Sin adjuntos

8.25 - Ciclo de vida de desarrollo seguro

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Ciclo de vida de desarrollo seguro bajo responsabilidad de la organización	1	1	BAJO (1)	*"La organización no desarrolla software. Los ajustes a la medida sobre el ERP los ejecuta el proveedor bajo el contrato CT-2024-08; la exigencia de desarrollo seguro se gestiona por la vía contractual y se evalúa en el control 8.30. Se deja constancia para sustentar la decisión de aplicabilidad."* Sin adjuntos

8.26 - Requisitos de seguridad de las aplicaciones

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Definición de los requisitos de seguridad de las aplicaciones	1	2	BAJO (2)	*"Los requisitos de seguridad se incorporan en la especificación funcional de los desarrollos. Se verifico en las dos solicitudes de cambio de 2026."* Sin adjuntos

8.27 - Principios de arquitectura de sistemas seguros

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Principios de arquitectura de sistemas seguros	1	2	BAJO (2)	*"La arquitectura de la publicación web sigue el principio de mínima exposición: solo los puertos 443 y 80 con redirección, detras del servicio del proveedor de hosting."* Sin adjuntos

8.28 - Codificación segura

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Aplicación de principios de codificación segura	2	4	MODERADO (8)	*"El portal de consulta de pedidos, desarrollado por un tercero, no valida las entradas: se comprobó que el parámetro de número de pedido permite consultar pedidos de otros clientes cambiando el identificador en la URL."* Sin adjuntos

8.29 - Pruebas de seguridad en desarrollo y aceptación

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Pruebas de seguridad durante el desarrollo y la aceptación	1	2	BAJO (2)	*"El protocolo de aceptación incluye pruebas de seguridad básicas y aprobación del dueño del proceso. Se verifico en los dos últimos pases a producción."* Sin adjuntos

8.30 - Desarrollo subcontratado

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Supervisión del desarrollo contratado con externos	1	2	BAJO (2)	*"El desarrollo contratado se supervisa con entregables, revisión de avance quincenal y aceptación formal documentada."* Sin adjuntos

8.31 - Separación de los entornos de desarrollo, prueba y producción

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Entornos de desarrollo y prueba mantenidos por la organización	1	1	BAJO (1)	*"La organización no mantiene entornos de desarrollo ni de prueba propios: los aloja y administra el proveedor del ERP, separados de producción en instancias distintas. Se verifico con el proveedor y se deja constancia para la decisión de aplicabilidad."* Sin adjuntos

8.33 - Información de prueba

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección de la información utilizada para pruebas	2	3	MODERADO (6)	*"La información de prueba se toma de producción sin selección, protección ni borrado posterior. No hay autorización registrada para su uso."* Sin adjuntos

8.34 - Protección de los sistemas de información durante las pruebas de auditoría

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección de los sistemas durante las pruebas de auditoría	1	2	BAJO (2)	*"Las actividades de esta auditoría se acordaron previamente con TI, en ventana definida y con alcance de solo lectura sobre los sistemas productivos."* Sin adjuntos

5.5 - Contacto con autoridades

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Contacto establecido y mantenido con las autoridades pertinentes	3	3	ALTO (9)	*"No hay puntos de contacto definidos con la Policía Nacional (CAI Virtual), la Superintendencia de Industria y Comercio ni el ColCERT. Ante un incidente no se sabría a quién notificar ni en qué plazo, pese a la obligación de la Ley 1581."* Sin adjuntos

7.11 - Servicios de suministro

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Protección de los servicios de suministro	1	2	BAJO (2)	*"La UPS cubre el servidor y el cuarto de comunicaciones con autonomía probada de 45 minutos. La planta eléctrica se prueba mensualmente con registro."* Sin adjuntos

8.13 - Copia de seguridad de la información

Criterio Evaluado	Prob.	Imp.	Riesgo	Hallazgo / Evidencia
Copias de seguridad realizadas y probadas	1	2	BAJO (2)	*"Respaldo diario incremental y semanal completo, con prueba de restauración mensual registrada. Se verifico la restauración del 04/04/2026, exitosa."* Sin adjuntos